

Монголбанк API холболтын заавар

Алт, мөнгөний сорьцын баталгаажсан дүнг Монголбанк талд аюулгүй дамжуулах интеграцийн зааварчилгааны хувилбар 0.1. Нууц түлхүүр, production endpoint, байгууллагын бодит зөвшөөрлийн жагсаалтыг энэ файлд оруулаагүй.

Баримтын төлөв	Дотоод хэлэлцүүлэгт зориулсан draft
Огноо	2026-08-29
Хамрах хүрээ	Монголбанк талын read/confirm integration
UI дээр харагдах эсэх	Хэрэглэгчийн цэсэнд харагдахгүй, зөвхөн PDF заавраар хүргэнэ

1. Зорилго

Сорьцын төвүүд алт, мөнгөний сорьцыг хүлээн авч, химич шинжилгээний дүн оруулж, эрхлэгч баталгаажуулсны дараа Монголбанк зөвхөн баталгаажсан мэдээллийг хүлээн авна. Монголбанк тал өөрийн системдээ тооцоолол, баталгаажуулалт, төлбөрийн дараагийн алхмыг хэрэгжүүлнэ.

Энэ integration нь public sign up эсвэл ердийн dashboard menu биш. API гэрээ, түлхүүр, IP зөвшөөрөл, signature шалгалт зэрэг мэдээллийг зөвхөн эрх бүхий техникийн сувгаар дамжуулна.

2. Оролцогч талууд

Тал	Үүрэг	Харах мэдээлэл
Сорьцын төв	Сорьц бүртгэх, шинжилгээ хийх, баталгаажуулах	Өөрийн төвийн бүрэн workflow
Монголбанк	Баталгаажсан дүн татах, тооцоолол ба confirmation буцаах	Баталгаажсан сорьцын дүн, банкны хуваарилалт
Арилжааны банк	Зөвхөн өөрт хуваарилагдсан металлын мэдээлэл харах	Өөрт оноосон хэмжээ, баталгаажсан дүн
Системийн супер админ	Хэрэглэгч, байгууллага, security policy удирдах	Бүх байгууллагын удирдлагын мэдээлэл

3. Ажлын урсгал

Алхам	Төлөв	Тайлбар
1	received	Сорьцын төв металл хүлээн авч, харилцагч болон банкны граммын хуваарилалтыг бүртгэнэ.
2	in_analysis	Химич жин, сорьц, цэвэр жин, аргачлал, багажийн мэдээллийг оруулна.
3	manager_review	Эрхлэгч maker-checker зарчмаар хянаж батална. Оруулсан хэрэглэгч өөрөө батлахгүй.
4	approved	Баталгаажсан дүн түгжигдэж, засвар нь шинэ revision болон audit мөрөөр явна.
5	bom_submitted	Монголбанк API зөвхөн баталгаажсан дүнг татах эсвэл webhook хэлбэрээр хүлээн авна.
6	bom_confirmed	Монголбанк тооцоолол, reference, confirmation төлөв буцааж бүртгүүлнэ.

4. Аюулгүй байдлын шаардлага

Шаардлага	Заавар
Transport	Зөвхөн HTTPS. Production дээр TLS 1.2 ба түүнээс дээш хувилбар ашиглана.
Authentication	Bearer token эсвэл mTLS + signed request. Нууц түлхүүрийг PDF, Git, screenshot-д хадгалахгүй.
IP allowlist	Монголбанк талын production outbound IP-г зөвшөөрлийн жагсаалтад оруулна.

Шаардлага	Заавар
Request signature	X-Timestamp, X-Request-Id, body hash дээр HMAC-SHA256 signature шалгана.
Idempotency	Давхар илгээхээс хамгаалж Idempotency-Key шаардлагатай.
Audit	Бүх уншилт, confirmation, алдаатай хүсэлт, signature failure бүр audit log-д бүртгэнэ.
Data lock	Баталгаажсан сорьцын дүнг шууд overwrite хийхгүй. Засвар нь шинэ revision үүсгэнэ.
No image by default	Одоогийн шаардлагаар зураг хадгалахгүй. Шаардлага нэмэгдвэл тусдаа encrypted object storage policy батална.

5. Санал болгож буй endpoint contract

Доорх замууд нь Монголбанк талд өгөх тусдаа integration namespace-ийн санал. Эдгээр нь хэрэглэгчийн dashboard-ийн internal route биш.

Method	Endpoint	Зорилго
GET	/bom/v1/assays	Баталгаажсан сорьцын жагсаалтыг since, centerCode, status filter-ээр татах.
GET	/bom/v1/assays/{publicId}	Нэг сорьцын дүн, банкны хуваарилалт, revision, audit reference татах.
POST	/bom/v1/assays/{publicId}/confirm	Монголбанк тооцоолол, reference number, confirmation төлөв буцаах.
GET	/bom/v1/health	Connectivity шалгах. Sensitive мэдээлэл буцаахгүй.

6. Request header

Header	Заавал эсэх	Тайлбар
Authorization	Тийм	Bearer token placeholder. Production token зөвхөн secret manager-д хадгална.
X-Request-Id	Тийм	Audit болон trace хийх UUID.
X-Timestamp	Тийм	ISO-8601 UTC timestamp. 5 минутын window-оос хэтэрвэл reject хийнэ.
X-Signature	Тийм	HMAC-SHA256 signature. Method, path, timestamp, body hash дээр тооцно.
Idempotency-Key	POST дээр тийм	Confirmation request давхар орж ирэхээс хамгаална.

7. Өгөгдлийн үндсэн талбарууд

Талбар	Төрөл	Тайлбар
publicId	string	Сорьцын төвөөс үүссэн public дугаар. Жишээ: AC-260829-001.
assayCenter	object	Сорьцын төвийн код, нэр, төрөл.
customer	object	Харилцагчийн төрөл, нэр, регистр/ID masking policy-ийн дагуу.
metalType	enum	gold эсвэл silver.
grossWeightGram	decimal	Нийт жин граммаар.
purityPercent	decimal	Сорьцын хувь. Жишээ: 89.7200.
fineWeightGram	decimal	Цэвэр жин. grossWeightGram * purityPercent / 100.
allocations	array	ВОМ эсвэл арилжааны банк тус бүрт хуваарилсан грамм.

Талбар	Төрөл	Тайлбар
approvedAt	datetime	Эрхлэгч баталгаажуулсан хугацаа.
revisionNo	integer	Дүнгийн хувилбар. Засвар бүр шинэ revision.
recordHash	string	Tamper-check хийх canonical record hash.

8. JSON жишээ

```
{
  "publicId": "AC-260829-001",
  "status": "approved",
  "assayCenter": { "code": "PMAC", "name": "Private assay center" },
  "customer": { "type": "organization", "name": "Example LLC" },
  "metalType": "gold",
  "grossWeightGram": "126.4500",
  "purityPercent": "89.7200",
  "fineWeightGram": "113.4599",
  "allocations": [
    { "receiverType": "bom", "receiverName": "Монголбанк", "weightGram": "56.4599" },
    { "receiverType": "commercial_bank", "receiverName": "Хаан банк", "weightGram": "70.0000" }
  ],
  "approvedAt": "2026-08-29T14:30:00Z",
  "revisionNo": 1,
  "recordHash": "sha256:..."
}
```

9. Error response

HTTP	code	Тайлбар
400	invalid_request	Filter, date, decimal format буруу.
401	unauthorized	Token байхгүй эсвэл буруу.
403	forbidden	IP allowlist, role, signature policy зөрчсөн.
404	not_found	publicId олдохгүй эсвэл тухайн integration-д харагдах эрхгүй.
409	state_conflict	Баталгаажаагүй сорьц эсвэл idempotency conflict.
429	rate_limited	Хэт олон хүсэлт илгээсэн.
500	internal_error	Дотоод серверийн алдаа. X-Request-Id-аар шалгана.

10. Нэвтрүүлэх checklist

#	Шалгах зүйл
0	Үнэ болон төлбөрийн тооцооллыг гаднаас шууд өөрчлөх боломж олгохгүй. Confirmation нь тусдаа бичилт байна.
1	Production endpoint, staging endpoint, contact window-г тусдаа баталгаажуулах.
2	Монголбанк талын outbound IP allowlist авах.
3	API token, signing secret-ийг password manager/secret manager-аар дамжуулах.
4	Signature verification болон replay protection дээр хамтарсан integration test хийх.
5	Maker-checker баталгаажсан сорьц л API дээр гарахыг test case-аар батлах.
6	Audit log дээр request id, actor, source IP, status, hash хадгалагдаж байгааг шалгах.
7	Алдаа, retry, idempotency behavior-ийг Монголбанк талтай тохиролцох.
8	Production go-live өмнө backup, incident response, key rotation procedure батлах.